

ZERO-TRUST AI FOR DISTRIBUTED ENTERPRISES

RBAC at every prompt. One audit trail across every replica.

Large organisations run AI across departments, regions, and shift patterns — so the gateway has to scale horizontally without losing the per-user RBAC story. systemprompt.io's scaled topology puts a stateless API tier behind one load balancer, enforces role-based gateway policy on every `/v1/messages` call via `PolicyResolver`, bridges in-process events across replicas with `Postgres LISTEN/NOTIFY`, and isolates cron to a single dedicated node — so jobs never double-fire and every request lands in one audit spine joined by `trace_id`.

AT A GLANCE

One gateway. N replicas. Same policy.

N

STATELESS REPLICAS · ONE LB

<500ms

P95 THROUGH THE LB

1

AUDIT TRAIL · TRACE_ID-JOINED

0

DUPLICATE CRON EXECUTIONS

01 Core capabilities

>

ENFORCE

Role-based gateway policy

Every call resolves `ai_gateway_policies` per user and role. Allow-listed models pass; everything else is a pre-connect 403 with the policy version logged.

Per-call RBAC

>

SCALE

Stateless API tier

One published port on the LB; `--scale app=N` registers every replica via docker DNS. Round-robin upstream, replica id stamped on every response.

x-served-by

>

BRIDGE

Cross-replica event bus

`PostgresEventBridge` relays the in-process bus over `LISTEN/NOTIFY`. SSE streams started on replica B receive events published on replica A.

LISTEN/NOTIFY

>

ISOLATE

Scheduler-of-one

Every app replica boots with a scheduler-disable override; one dedicated node with `deploy.replicas: 1` runs cron. No duplicate executions under load.

Single-writer cron

02 Why distributed enterprises choose systemprompt.io

→

RBAC at the gateway, not at the seat

Role → policy → model allow-list, resolved per call. Finance can call Bedrock-hosted Claude; engineering can call on-prem Llama; auditors can call neither. Revoke a role at the gateway and the change lands within one TTL window — SSO untouched.

→

One audit spine across the fleet

Every replica writes to one `postgres-primary`. Every prompt, tool call, MCP execution and cost row is joined by `trace_id`. The auditor's question is a SQL query, not a search across N container logs.

→

Horizontal scale without operational drift

Sustained-load soak ships in the demo: latency drift ≤5%, no growing memory. Connection-pool exhaustion, GC pressure, leak-led p95 creep — surfaced before production, not after.

TOPOLOGY	LB → N stateless <code>app</code> replicas + one isolated <code>scheduler</code> . Primary/replica <code>Postgres</code> with streaming WAL (<code>wal_level=replica</code>).
LB TUNING	<code>proxy_buffering off</code> , <code>proxy_read_timeout 3600s</code> , <code>resolver 127.0.0.11 valid=10s</code> . Streaming-tuned for SSE; round-robin on docker DNS.
IDENTITY	JWT-bound role; <code>PolicyResolver.resolve()</code> with 60s cache over <code>ai_gateway_policies</code> ; per-user, per-role plugin catalogue resolution.
DEPLOYMENT	Docker Compose <code>--scale app=N</code> · Kubernetes Deployment + HPA. Single binary per replica; profile copied into each writable layer to avoid shared-mount races.
OBSERVABILITY	<code>OpenTelemetry</code> traces, <code>x-served-by</code> on every response, soak-time memory + p95 sampler. <code>Splunk</code> · <code>ELK</code> · <code>Datadog</code> exporters.
COMPLIANCE	SOC 2 (CC6.1, CC7.2), ISO 27001 (A.5.15, A.8.3, A.8.25), HIPAA §164.312, EU AI Act Art. 9/12/15, NIST AI RMF, OWASP Agentic Top 10.

PROVIDER-AGNOSTIC · PER-ROLE ROUTING

Direct: Anthropic · OpenAI · Gemini · Groq Cloud: Bedrock · Vertex AI · Azure Foundry

Self-hosted: Llama · Qwen · any `/v1/messages` Routing: per-call · per-role · per-region

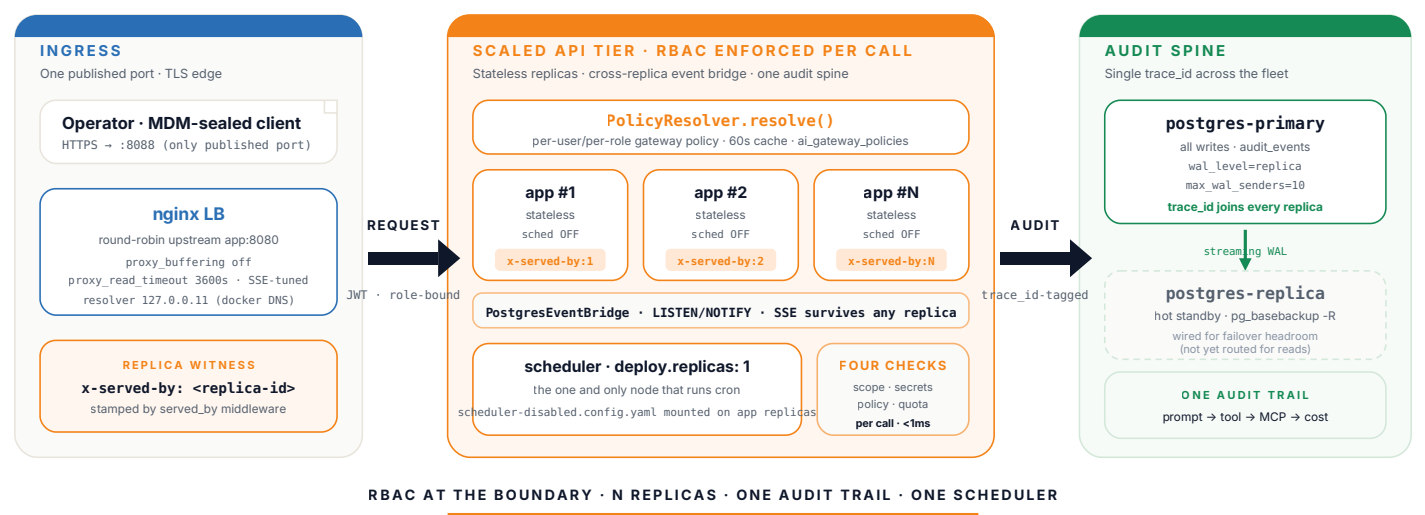
Evaluate the scaled topology free. From single host to multi-replica in one command.

`just scaled-up` brings up LB + replicas + scheduler + primary/replica Postgres. The four assertion scripts prove fairness, the event bridge, scheduler isolation, and soak-time drift.

github.com/systempromptio/systemprompt-template

ed@systemprompt.io

03 One LB, N replicas, one scheduler: the scaled topology



RBAC AT THE BOUNDARY Every replica enforces the same role-bound policy and writes to the same postgres-primary. The hot standby is wired for failover headroom; the engine does not yet read from it (called out as an open item in the scenario's known-limits).

04 RBAC granularity, on infrastructure you own

	Vanilla Claude Enterprise	Single-instance gateway	Scaled + systemprompt.io
ACCESS & IDENTITY			
RBAC granularity	Seat / SSO group	Tenant-level	Per-user, per-role, per-call
Revoke a role	Remove from SSO group	Edit YAML, redeploy	One DB row. SSO untouched. < one TTL window.
SCALE & RELIABILITY			
Horizontal scale	Anthropic-managed	One process · vertical only	--scale app=N; nginx round-robin; replica id stamped per response
Cross-replica events	N/A	In-process only	PostgresEventBridge · LISTEN/NOTIFY · SSE crosses replicas
Cron de-duplication	N/A	In-process mutex (breaks across replicas)	Scheduler-of-one · deployment-time isolation

05 Built for the teams running AI for the whole enterprise

FOR THE PLATFORM LEAD

One gateway, N replicas, same SLO.

Stateless replicas, predictable scale-out, an LB that already knows SSE. The soak harness, the fairness assertion, and the scheduler-isolation test ship with the demo — runnable on a laptop before they hit production.

Outcome: Capacity becomes a number, not a debate.

FOR THE SECURITY OFFICER

Role → policy → audit row, in one query.

Every prompt landed against a versioned policy. Every tool call joined by trace_id. Revocation is a row change at the gateway — no rolling restart, no waiting on SSO propagation, no collateral access loss.

Outcome: RBAC that survives the audit.

Read the scaled scenario walkthrough. **Topology, scripts, soak analysis, scheduler-isolation proof.**

Four runnable scripts: LB-fronted load, soak with drift detection, LB fairness + cross-replica event delivery, scheduler isolation under sustained cron.

demo/scenarios/scaled/architecture.md